BA REQUIREMENTS SPECIFICATION

Dac ta he thong IT Asset Inventory & Security Posture

Mot nguon su that duy nhat ve ha tang, ung dung va be mat tan cong - tim gi co do, thay CVE la biet phai lam gi.

Hang muc	Thong tin
Ten tai lieu	Software Requirements Specification (SRS) hop nhat Business Requirements (BRD)
Phien ban	1.0 - Ban giao cho doi phat trien (dev-ready)
Ngay ban hanh	23/10/2026
Trang thai	CHO PHE DUYET (Pending approval cua khach hang / chu dau tu)
Phan loai	NOI BO - CONFIDENTIAL. Chua du lieu ha tang nhay cam, khong gui ra ngoai cong ty.
Nguoi dong vai tro BA	Muse (Business Analyst) - dua tren brief cua khach hang ngay 23/10/2026
Khach hang / Sponsor	Chu he thong ha tang - nguoi ra quyet dinh pham vi va uu tien
Doi thuc hien	Dev team noi bo cua cong ty (da co san), QA, DevOps/SRE, Security
Cong nghe nen du kien	Web app; osquery (osqueryi / FleetDM tuy chon); API cua Docker, Kubernetes, Traefik, Pomerium, Keycloak, Cloudflare; NVD / GHSA / OSV / CISA KEV

Tai lieu nay tra loi ba cau hoi: (1) Chung ta dang co gi, o dau, phien ban nao? (2) Cai gi dang mo ra Internet, qua duong nao, ai duoc vao? (3) Khi mot CVE cong bo, chung ta bi anh huong o dau va phai lam gi truoc? Moi yeu cau deu co ma so (FR-xx, NFR-xx, US-xx) de dev, QA va khach hang cung truy vet.

Muc luc

1. Gioi thieu, muc dich va cach doc tai lieu

2. Bai toan hien trang (As-Is) va hau qua

3. Tam nhin, muc tieu va KPI do thanh cong

4. Pham vi: In-scope, Out-of-scope, Phase 1/2/3

5. Stakeholders, nguoi dung va phan quyen

6. Gia dinh, rang buoc va phu thuoc

7. Kien truc he thong va nguyen tac thiet ke

8. Mo hinh du lieu (Data Model)

9. FR-01 Discovery va Inventory

10. FR-02 Tech Stack va Version Intelligence

11. FR-03 Network, Firewall va Traffic Flow

12. FR-04 Domain, DNS va Cloudflare Mapping

13. FR-05 Edge, Route va Policy: Traefik, Pomerium, Keycloak

14. FR-06 Exposure va Attack Surface

15. FR-07 CVE Impact Analysis va Remediation

16. FR-08 Search, Dashboard va Bao cao

17. FR-09 Alerting, FR-10 Ownership, FR-11 Audit va FR-12 Du lieu lich su

18. Luong nghiep vu chinh (Use Cases)

19. User Stories va tieu chi nghiem thu tong hop

20. API Specification

21. Bao mat cho chinh platform (Security of the Platform)

22. Yeu cau phi chuc nang (NFR)

23. Tich hop ben ngoai va Collector Specification

24. Van hanh, giam sat va SLO

25. Ke hoach trien khai, Migration va Roadmap

26. Rui ro, van de mo va quyet dinh can chot

Phu luc A. Bang thuat ngu

Phu luc B. Vi du truy van osquery

Phu luc C. Cong thuc tinh Risk Score

> **Luu y:** Cach doc: Lanh dao doc muc 2, 3, 4, 25. Dev doc muc 7, 8, 9-17, 20, 23. QA doc muc 18, 19, 22 va tieu chi nghiem thu trong tung FR. Security doc muc 14, 15, 21. Moi xung dot giua cac muc: muc co ma FR/NFR cu the duoc uu tien hon phan mo ta chung.

1. Gioi thieu, muc dich va cach doc tai lieu

Cong ty dang van hanh nhieu ung dung tren ha tang do doi ha tang tu dung va tu phat trien theo nhu cau tung thoi ky: co ung dung chay truc tiep tren host (bare-metal / VM), co ung dung dong goi bang Docker va Docker Compose, co cum Kubernetes. Qua thoi gian, khong con mot ban do day du va dang tin cay ve toan bo he thong. Tai lieu nay dac ta mot ung dung web noi bo - tam goi la **IT Asset & Security Posture Platform** (sau day goi tat la *Platform*) - de giai quyet bai toan do.

Muc dich cua tai lieu la bien y tuong o muc chu truong thanh dac ta du chi tiet de doi dev bat tay xay dung ma khong phai tu doan cac quyet dinh nghiep vu quan trong. Tai lieu dong thoi la co so de nghiem thu: mot tinh nang chi duoc coi la xong khi thoa cac tieu chi nghiem thu ghi trong muc tuong ung va trong muc 19.

1.1 Nguyen tac xuyen suot: Tim gi co do

Moi man hinh, moi API va moi bao cao cua Platform deu phuc vu mot hanh vi cot loi: nguoi dung dat mot cau hoi bat ky ve ha tang va nhan duoc cau tra loi co bang chung, co nguon goc va co thoi diem cap nhat. Vi du cac cau hoi phai tra loi duoc trong duoi 30 giay: "Tat ca noi nao dang chay Log4j 2.14?" - "Domain app.example.com cuoi cung di toi container nao, tren host nao?" - "Port 5432 cua host nao dang mo ra Internet?" - "Service nay ai so huu, public hay chi noi bo, dang khoa bang chinh sach nao?" Neu mot cau hoi thuoc nhom nay khong tra loi duoc, do la thieu sot chuc nang, khong phai han che chap nhan duoc.

1.2 Doi tuong doc va quyen quyet dinh

Doi tuong	Quyen / trach nhiem
Sponsor (khach hang)	Phe duyet pham vi, uu tien, KPI muc 3 va cac quyet dinh mo o muc 26
BA / Product Owner	Giu dac ta, lam ro yeu cau, chot thay doi qua Change Log
Tech Lead / Architect	Phe duyet kien truc muc 7, mo hinh du lieu muc 8, API muc 20
Dev team	Thuc hien theo FR, bao cao lech dac ta truoc khi tu thay doi
QA	Viet test case tu Use Case muc 18 va Acceptance Criteria
Security / Infra	Cung cap quyen truy cap nguon du lieu, xac nhan rule phat hien va muc do rui ro

1.3 Tai lieu tham chieu

- NVD (National Vulnerability Database) va dinh dang CPE/CVE cua NIST.
- CISA Known Exploited Vulnerabilities (KEV) Catalog - danh sach CVE dang bi khai thac thuc te.
- OSV va GitHub Advisory Database (GHSA) cho vulnerability cua thu vien / package.
- Tai lieu osquery: schema cac bang (processes, listening_ports, docker_containers, deb_packages, rpm_packages, programs...).
- Tai lieu API cua Kubernetes, Docker Engine, Traefik, Pomerium, Keycloak va Cloudflare (API v4).
- OWASP ASVS va OWASP Top 10 cho bao mat cua chinh Platform (muc 21).

> **Luu y:** Ten san pham, ten mien va dia chi IP trong vi du cua tai lieu nay la gia dinh de minh hoa (vi du: app.example.com, 203.0.113.10 - dai IP tai lieu RFC 5737). Dev khong duoc hard-code bat ky gia tri vi du nao vao he thong.

2. Bai toan hien trang (As-Is) va hau qua

2.1 Hien trang da xac nhan tu brief cua khach hang

Linh vuc	Hien trang	Hau qua truc tiep
Mo hinh chay	App chay lung tung: host, Docker, Kubernetes, khong co chuan thong nhat	Khong biet mot service dang song o dau, trung lap hay da chet
Tech stack / version	Khong ro web/app chay tech gi, version khac nhau giua cac noi	Khong danh gia duoc loi thoi, het ho tro (EOL) va pham vi anh huong CVE
Network / firewall	Khong nam duoc ket noi mo nhu the nao, config network va firewall ra sao	Be mat tan cong an; nguy co mo port thua, rule qua rong (0.0.0.0/0)
Traefik	Dung de route va gan policy nhung phan tan, khong control tong the	Route trung, route mo (orphan), policy khong nhat quan, kho audit
Pomerium + Keycloak	Co IdP va policy nhung khong co tam nhin tong quan	Khong biet app nao da siet xac thuc, app nao dang public khong bao ve
Domain / DNS	Khong ro domain tro host nao, service nao, IP nao; DNS qua Cloudflare	Su co DNS kho truy vet; subdomain treo (dangling) co nguy co bi chiem (takeover)
Du lieu san co	Co full log va truy cap duoc hau het host bang osquery	Day la loi the lon nhat: du kha nang discovery ma khong can dung lai he thong

2.2 Nam hau qua neu khong lam

1. **Ung pho CVE cham va thu cong:** moi khi co CVE nghiem trong, doi ngu phai ra soat bang tay tung host, tung repo - mat hang gio den hang ngay, va van bo sot.
2. **Khong chung minh duoc tuan thu:** khong tra loi duoc cau hoi kiem toan "liet ke tat ca tai san va chu so huu" la mot diem tru nang trong moi dot audit bao mat.
3. **Su co keo dai:** khong co ban do phu thuoc, khi mot host chet khong biet service nao bi anh huong theo.
4. **No ky thuat am tham:** version lech nhau, image cu, container chay bang root, secret lo trong bien moi truong - tat ca tich luy khong ai thay.
5. **Quy mo cang lon, chi phi ra soat cang tang theo cap so:** moi service moi khong dang ky lam tam nhin chung mo them mot chut.

> **Canh bao:** Gia dinh lam viec cua BA: hien trang khong co CMDB dang tin cay. Vi vay Platform phai tu discovery va doi chieu nhieu nguon, tuyet doi khong yeu cau con nguoi nhap tay inventory lam nguon chinh - nhap tay chi dung de bo sung metadata (chu so huu, muc do quan trong) ma may khong tu biet duoc.

3. Tam nhin, muc tieu va KPI do thanh cong

3.1 Tam nhin (Vision)

Bat ky ai co quyen trong cong ty, khi can biet bat ky dieu gi ve ha tang va muc do an toan cua no, chi can mo Platform va tim la thay - day du, co bang chung, cap nhat gan nhat va biet ro du lieu do den tu dau, luc nao.

3.2 Quy mo thuc te - co so de thiet ke va uoc luong

Hang muc	Quy mo xac nhan	Anh huong thiet ke
Host server	Khoang 150 host	Doi tuong discovery uu tien so 1; chay osquery day du, quet sau va lien tuc
Workstation	Khoang 500 may tram	Uu tien THAP; quan ly don gian theo site, khong can chi tiet nhu server (xem FR-01.7)
Kubernetes	2 cluster: 1 dev, 1 prod	Tich hop rieng cho tung cluster; moi truong prod duoc uu tien canh bao va bao ve thay doi
Cloudflare	Chi READ-ONLY	Chi doc DNS records; tuyet doi khong sua DNS tu Platform (xem muc 6 va FR-04)
Nguon du lieu khac	Docker host, Traefik, Pomerium, Keycloak, log tap trung	Collector doc qua API / log, uu tien agentless khi co the

> **Luu y:** Moi uoc luong dung luong, tan suat quet va thiet ke collector trong tai lieu nay deu dua tren quy mo tren. Neu quy mo tang gap 3 lan (vi du tren 500 server), phai danh gia lai muc 22 (NFR hieu nang) truoc khi mo rong.

3.3 Muc tieu kinh doanh va ky thuat

Ma	Muc tieu	Chi so do (KPI) va nguong dat
GO-01	Mot nguon su that ve tai san	>=98% server trong tam quan ly co ho so day du; <2% tai san "khong ro chu so huu" sau 90 ngay
GO-02	Rut ngan ung pho CVE	Tu luc CVE cong bo den bao cao anh huong (host/service/version) <= 60 phut tu dong; truoc day do bang tay hang gio/ngay
GO-03	Kiem soat be mat tan cong	100% dich vu public co ghi nhan: duong vao, policy, IdP, whitelist; canh bao moi exposure moi trong <= 15 phut
GO-04	Giam no version / EOL	Danh sach EOL va version lech duoc cap nhat hang ngay; giam >=50% thanh phan EOL trong 6 thang
GO-05	San sang audit	Xuat bao cao inventory + ownership + exposure theo yeu cau audit trong <= 1 ngay lam viec
GO-06	Khong lam gian doan san xuat	Discovery read-only, khong thay doi he thong duoc quan ly; 0 su co san xuat do Platform gay ra

3.4 Nguyen tac san pham

- **Read-only truoc tien:** Phase 1 va 2 chi doc, phan tich, canh bao va khuyen nghi. Khong tu dong sua, xoa, chan hay restart bat ky thu gi tren he thong dich.
- **Co bang chung moi ket luan co bang chung:** moi phat hien phai tro ve nguon (source), thoi diem (observed_at) va du lieu tho (raw_ref) de kiem chung lai duoc.
- **Thua nhan khong chac chan:** du lieu suy luan phai gan nhan do tin cay (confidence: confirmed / inferred / stale) thay vi trinh bay nhu su that chac chan.
- **Uu tien theo rui ro thuc te:** CVE dang bi khai thac (KEV), co exploit, lo ra Internet va chua co IdP phai noi len truoc hang nghin CVE ly thuyet khac.

4. Pham vi: In-scope, Out-of-scope, Phase 1/2/3

4.1 In-scope - Phase 1 (MVP)

- Discovery va inventory cho 150 server (host, Docker, Kubernetes) - chi tiet o FR-01 den FR-03.
- Quan ly workstation o muc don gian theo site: dem so luong, trang thai online/offline, OS chinh, lan check-in cuoi - khong quet sau tung may (FR-01.7).
- Anh xa domain - DNS (Cloudflare, read-only) - IP - host - service (FR-04).
- Tong hop route va policy cua Traefik, Pomerium va trang thai IdP cua Keycloak (FR-05).
- Exposure analysis va canh bao dich vu public khong bao ve (FR-06).
- CVE impact analysis cho OS package, runtime, framework va container image (FR-07).
- Tim kiem toan van, dashboard, bao cao va xuat file (FR-08); canh bao qua email/chat (FR-09).

4.2 Out-of-scope (khong lam trong tai lieu nay)

- Tu dong remediation: khong tu va, khong tu nang version, khong tu sua firewall, khong tu sua DNS Cloudflare, khong tu restart service. Moi khuyen nghi chi dung o muc de xuat va (neu co) tao ticket.
- Thay the SIEM, EDR, WAF, he thong giam sat (monitoring/alerting ha tang) hay cong cu quet lo hong chuyen sau (DAST/SAST). Platform tieu thu va lien ket du lieu cua cac he thong do, khong thay the chung.
- Quan ly chi tiet workstation nhu server: khong thu thap process, port, package chi tiet tren 500 workstation trong Phase 1/2.
- Quan ly tai san vat ly (phong may, switch, UPS), tai san phan mem ban quyen thuong mai va chi phi (FinOps) - chi ghi nhan neu can cho ownership.
- Quet mang (network scanning) chu dong dang aggressive co the lam gian doan dich vu, tru khi duoc phe duyet rieng bang van ban.

4.3 Lo trinh giai doan

Giai doan	Noi dung chinh	Dieu kien ra khoi giai doan (Exit criteria)
Phase 1 - MVP	Discovery server, inventory, stack/version, DNS mapping, exposure co ban, CVE cho OS package va image, search + dashboard	Chay on dinh tren 150 server va 2 cluster; KPI GO-02 dat tren du lieu mau kiem chung thu cong
Phase 2	Traffic flow sau, policy analysis Traefik/Pomerium/Keycloak day du, drift detection, ownership workflow, workstation theo site day du	>=95% service co owner; canh bao drift van hanh duoc 30 ngay khong bao dong gia qua nguong
Phase 3	Lien ket SIEM/log sau, remediation workflow co phe duyet (van khong tu dong sua Cloudflare DNS), bao cao tuan thu, API cho he thong khac tieu thu	Quy trinh phe duyet remediation duoc Sponsor ky duyet rieng; audit log day du

> **Canh bao:** Cloudflare READ-ONLY la rang buoc cung o moi giai doan, ke ca Phase 3: Platform khong bao gio giu quyen ghi Cloudflare va khong tu dong sua DNS trong bat ky remediation playbook nao. Noi dung lien quan chi o muc khuyen nghi (xem FR-04 va FR-07).

5. Stakeholders, nguoi dung va phan quyen

5.1 Cac ben lien quan

Ben	Quan tam chinh	Quyen quyet dinh
Sponsor / Chu dau tu	Tam nhin tong the, rui ro, tien do	Phe duyet pham vi, KPI, Phase 3 remediation
Infra Lead	Discovery dung, khong anh huong san xuat	Phe duyet cach truy cap host, lich quet
Security Lead	Exposure, CVE, policy	Phe duyet rule rui ro, nguong canh bao
Dev / DevOps cac team dich vu	Service cua minh dung, khong bi gan nhan sai	Xac nhan ownership, phan hoi phat hien sai (false positive)
Helpdesk / IT theo site	Workstation theo site	Cap nhat thong tin site, trang thai may tram
Auditor (doc)	Bang chung, lich su thay doi	Chi doc, khong sua du lieu

5.2 Vai tro nguoi dung (RBAC)

Vai tro	Quyen xem	Quyen sua / hanh dong
Admin	Toan bo	Quan ly nguoi dung, collector, cau hinh quet, nguon du lieu
Security Analyst	Toan bo	Danh dau CVE, tao remediation recommendation, xac nhan ngoai le rui ro
Infra Engineer	Toan bo	Cap nhat metadata tai san, xac nhan drift hop le
Service Owner	Service cua minh + lien quan	Xac nhan ownership, phan hoi phat hien, xin ngoai le co thoi han
Viewer	Toan bo (an truong nhay cam)	Khong sua; chi tim kiem, xem bao cao
Auditor	Toan bo (chi doc, co log truy cap)	Xuat bao cao; khong sua, khong xem secret
API Service Account	Theo scope duoc cap	Chi doc API hoac chi ghi ingest, tach rieng tung collector

Nguyen tac: mac dinh it quyen nhat (least privilege). Truong nhay cam nhu bien moi truong, gia tri secret, token va khoa rieng khong bao gio hien thi - he thong chi ghi nhan "co ton tai bien X" va nguon cua no, khong luu gia tri tho (xem muc 21). Moi quyen ghi deu ghi audit log bat bien.

Tieu chi nghiem thu (Acceptance Criteria):

- Nguoi dung khong co vai tro phu hop khong thay duoc nut hanh dong bi cam, va API tra 403 neu goi truc tiep.
- Moi thay doi metadata deu luu: ai, luc nao, gia tri cu, gia tri moi.
- Dang nhap bat buoc qua SSO (Keycloak hien co) va MFA cho Admin, Security Analyst.

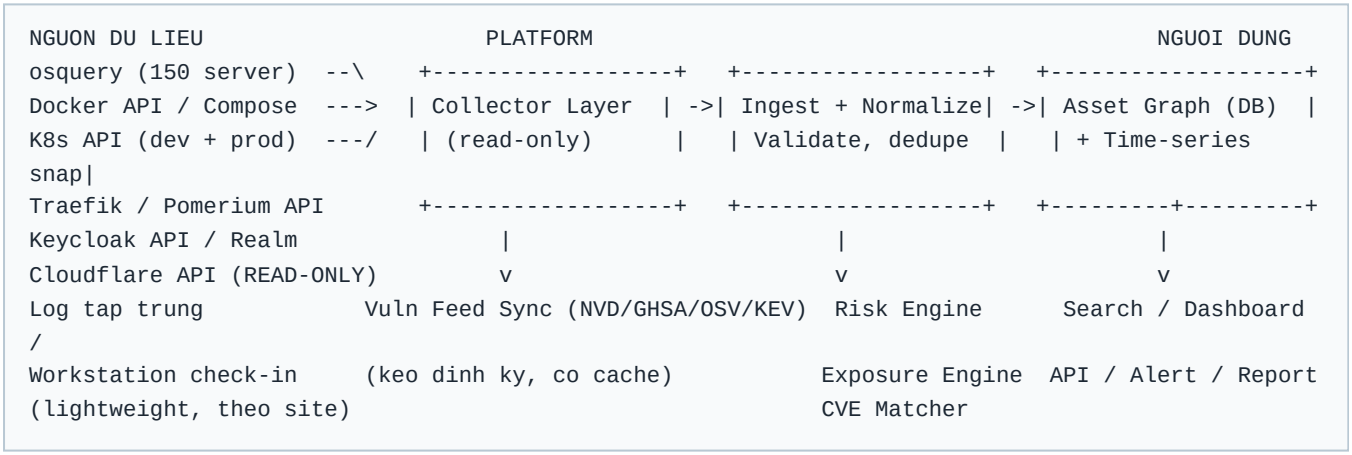
6. Gia dinh, rang buoc va phu thuoc

Ma	Noi dung	Loại
A-01	Co osquery tren hau het server va co full log tap trung	Gia dinh - can xac nhan lai ty le phu trong tuan 1 trien khai

Ma	Noi dung	Loại
A-02	500 workstation chi can quan ly theo site, khong can discovery sau	Xac nhan tu khach hang 23/10/2026
C-01	Cloudflare chi READ-ONLY: chi doc DNS records bang API token read-only	Rang buoc cung
C-02	Discovery uu tien server; workstation chi lightweight check-in theo site	Rang buoc pham vi
C-03	Phase 1-2 read-only voi he thong dich; khong remediation tu dong	Rang buoc cung
C-04	Du lieu ha tang la nhay cam: Platform phai dat muc bao mat tuong duong he thong san xuat quan trong nhat	Rang buoc bao mat
D-01	Phu thuoc Keycloak lam IdP cho dang nhap Platform va lam nguon du lieu policy	Phu thuoc
D-02	Phu thuoc NVD/GHSA/OSV/KEV cap nhat dinh ky; phai co co che cache va van hanh khi nguon ngoai gian doan	Phu thuoc
D-03	Phu thuoc quyen doc API cua Docker, Kubernetes (2 cluster), Traefik, Pomerium, Cloudflare	Phu thuoc - can cap phat truoc Sprint 1

> **Luu y:** Neu A-01 sai (ty le host co osquery thap hon du kien), ke hoach discovery phai bo sung phuong an agentless (SSH/WinRM doc lenh, API cloud/virtualization) va thoi gian Phase 1 se tang - day la rui ro R-01 o muc 26.

7. Kien truc he thong va nguyen tac thiet ke



7.1 Cac lop kien truc

Lop	Trach nhiem	Yeu cau ky thuat chinh
Collector	Doc du lieu tu tung nguon theo lich va theo su kien; khong ghi gi len nguon	Moi collector doc lap, chet mot cai khong keo chet cac cai khac; co retry va backoff; ghi ro nguon + thoi diem
Ingest + Normalize	Chuan hoa ve mo hinh du lieu chung (muc 8); loai trung; gan danh tinh on dinh cho tai san	Xu ly idempotent: gui lai cung mot du lieu khong tao ban sao; co hang doi (queue) de chiu tai dot bien
Asset Graph	Luu quan he: host - service - container - domain - policy - nguoi so huu	Truy van quan he nhieu bac (domain di toi container nao) phai tra loi nhanh (muc 22)

Lop	Trach nhiem	Yeu cau ky thuat chinh
Risk / CVE Engine	Doi chieu version voi co so du lieu lo hong; tinh diem rui ro; phat hien exposure va drift	Quy tac tinh diem phai giai thich duoc tung yeu to (Phu luc C); cap nhat feed khong can deploy lai code
Trinh dien / API	Web UI, tim kiem, dashboard, bao cao, API va canh bao	Moi du lieu tren UI deu bam duoc ve chi tiet va bang chung nguon

7.2 Nguyen tac thiet ke bat buoc

- **Danh tinh on dinh (stable identity):** moi tai san co ID noi bo khong doi theo IP/hostname don thuan; dung nhieu dau hieu (host UUID, cloud instance ID, K8s UID, container image digest) de nhan dien khi tai san thay IP hoac duoc tao lai.
- **Phan biet "da xac nhan" va "suy luan":** quan he do collector doc truc tiep la confirmed; quan he suy ra tu log/DNS la inferred kem do tin cay phan tram.
- **Lich su la san pham:** moi lan quet tao snapshot; he thong tra loi duoc "hom qua khac hom nay o diem nao" (drift) chu khong chi trang thai hien tai.
- **Collector that bai phai lo ra:** nguon nao im lang qua nguong (vi du server khong bao du lieu tren 24 gio) phai sinh canh bao "mat tam nhin", khong duoc am tham coi nhu tai san da bien mat.
- **Tach moi truong:** du lieu dev va prod cung mot Platform nhung gan nhan ro; canh bao, muc do nghiem trong va quyen sua phan biet theo moi truong, prod la mac dinh khi loc chua chon.

8. Mo hinh du lieu (Data Model)

Moi entity deu co cac truong chung: `id` (UUID noi bo), `source` (collector/nguon phat hien), `first_seen_at`, `last_seen_at`, `observed_at` (thoi diem du lieu duoc do o nguon), `confidence` (confirmed/inferred/stale), `raw_ref` (con tro toi du lieu tho da luu), `tags`, `owner_id` (neu co), `environment` (dev/prod/staging/khac) va `site_id` (neu lien quan). Xoa mem (soft delete) la mac dinh: tai san khong con thay se chuyen trang thai *missing*, sau nguong cau hinh moi chuyen *retired*, khong xoa khoi lich su.

Entity: Host / Server

Truong chinh: `hostname, host_uuid, ip_addresses[], mac, os, os_version, kernel, cpu, ram, disk, virtualization, cloud_provider, site_id, agent_status, last_boot`

La trung tam cua inventory server. 150 ban ghi ky vong o trang thai active.

Entity: Workstation

Truong chinh: `hostname, os, os_major_version, site_id, assigned_user (chi ten dang nhap, khong du lieu ca nhan thua), last_checkin_at, status`

Quan ly don gian theo site; khong co process/port/package chi tiet. 500 ban ghi ky vong.

Entity: Site

Truong chinh: `name, address_summary, contact, workstation_count (tu tinh), server_count (tu tinh)`

Don vi gom workstation va co the gom ca server dat tai cho.

Entity: Service / Application

Truong chinh: `name, display_name, owner_id, criticality (critical/high/medium/low), repo_url, lifecycle (active/deprecated/planned), description`

Service la don vi nghiep vu; mot service co nhieu deployment.

Entity: Deployment

Truong chinh: `service_id, environment, host_id / cluster_id, namespace, replicas, image_ref, image_digest, started_at, version_label`

Mot lan chay cu the cua service o mot moi truong.

Entity: Container

Truong chinh: `container_id, image, image_digest, runtime (docker/k8s), host_id, ports[], mounts, privileged, run_as_user, restart_count`

Privileged va chay bang root la cac truong rui ro phai truy van duoc.

Entity: Image

Truong chinh: `repository, tag, digest, os_base, size, created_at, known_vuln_summary, last_scanned_at`

Digest la dinh danh chinh; tag chi la nhan phu vi tag co the bi ghi de.

Entity: Package / Library

Truong chinh: `name, version, ecosystem (deb/rpm/npm/pip/go/maven...), source_host_or_image, license, is_eol`

Don vi de doi chieu CVE va EOL. Version phai luu ca chuoi goc va version da chuan hoa.

Entity: Runtime / Stack

Truong chinh: `type (jvm/node/python/nginx/postgres...), name, version, eol_date, support_status`

Phuc vu FR-02 va canh bao EOL.

Entity: Network Interface / IP

Truong chinh: `host_id, interface, ip, cidr, is_public, mac`

Phan biet IP noi bo, IP public va IP cua Cloudflare edge.

Entity: Listening Port

Truong chinh: `host_id/container_id, protocol, port, bind_address, process, pid, is_exposed`

Bind 0.0.0.0 khac han bind 127.0.0.1 ve rui ro - phai luu bind_address.

Entity: Firewall Rule

Truong chinh: `source_system (host firewall / security group / K8s NetworkPolicy), action, src_cidr, dst, ports, direction`

Luu ca rule hieu luc va nguon quan ly rule do.

Entity: Domain

Truong chinh: `fqdn, registrar_note, is_internal, primary_service_id`

Domain la diem vao tu goc nhin nguoi dung va ke tan cong.

Entity: DNS Record

Truong chinh: `domain, type (A/AAAA/CNAME/TXT...), value, proxied (Cloudflare), ttl, observed_at`

Chi doc tu Cloudflare; moi thay doi chi duoc phat hien va ghi nhan, khong duoc sua (FR-04).

Entity: Certificate

Truong chinh: `domain, issuer, subject, san[], not_before, not_after, source, fingerprint`

Canh bao het han truoc 30/14/7 ngay.

Entity: Route (Traefik)

Truong chinh: `router_name, rule_host, rule_path, service_target, middlewares[], tls, entrypoint, source_config`

Gom tu nhieu nguon cau hinh Traefik phan tan ve mot cho.

Entity: Access Policy

Truong chinh: `system (Pomerium/Traefik/Keycloak), route_ref, allowed_groups[], allowed_domains, mfa_required, public_allowed`

Tra loi cau hoi: ai duoc vao, bang dieu kien gi.

Entity: Identity Group / Role

Truong chinh: `idp (Keycloak), realm, client_id, groups[], roles[], user_count`

Chi luu nhom/vai tro va so luong, khong luu du lieu ca nhan thua cua nguoi dung IdP.

Entity: Vulnerability (CVE)

Truong chinh: `cve_id, aliases (GHSA...), cvss, severity, kev_listed, epss, published_at, fixed_versions[], references[]`

Du lieu dong bo tu NVD/GHSA/OSV/KEV; khong tu sua tay.

Entity: Finding

Truong chinh: `type (cve/exposure/drift/eol/misconfig), entity_ref, severity, risk_score, status, first_found, last_found, evidence_ref`

Don vi cong viec cua Security Analyst; co vong doi o muc 15.3.

Entity: Owner / Team

Truong chinh: `team_name, members, contact_channel, escalation`

Ownership co the gan cho host, service, domain hoac site.

Entity: Scan / Collection Run

Truong chinh: `collector, started_at, finished_at, status, records_seen, errors[], scope`

Moi dot thu thap la mot ban ghi kiem toan duoc.

8.1 Quan he cot loi phai truy van duoc

- Domain -> DNS Record -> IP / Cloudflare Proxy -> Host / Load Balancer -> Route (Traefik) -> Access Policy (Pomerium) -> Service -> Deployment -> Container -> Image -> Package.
- Host -> Listening Port -> Process -> Service; Host -> Firewall Rule -> Network exposure.
- Service -> Owner/Team; Service -> Runtime/Stack -> Package -> Vulnerability (CVE) -> Finding -> Remediation Recommendation.
- Site -> Workstation (nhieu); Site -> Host (neu server dat tai site).

> **Tieu chi nghiem thu (Acceptance Criteria):**

- Dev dung muc nay de dung schema; moi quan he tren phai co truy van API tuong ung o muc 20 va co test.
- Khong entity nao thieu 5 truong chung: source, first_seen_at, last_seen_at, confidence, raw_ref (tru Site/Owner do con nguoi khai bao thi source la manual).

9. FR-01 Discovery va Inventory

FR-01.1 Discovery server qua osquery (uu tien so 1)

He thong dung osquery tren server lam nguon discovery chinh: dinh ky chay cac truy van da duyet (Phu luc B) de thu thap thong tin host, he dieu hanh, package, process dang nghe cong, dich vu, tai khoan dich vu, cron/scheduled task, container (neu co) va trang thai agent. Tan suat mac dinh: inventory co ban moi 15 phut, quet sau (package/process) moi 6 gio, co the cau hinh theo nhom host. Ket qua ve Ingest qua hang doi, duoc chuan hoa va doi chieu voi snapshot truoc de phat hien thay doi.

Tieu chi nghiem thu (Acceptance Criteria):

- Mot server moi cai osquery va duoc cap quyen se xuat hien tren Platform trong <= 30 phut ke tu lan chay dau tien, kem day du hostname, IP, OS, version.
- Server ngung bao du lieu tren 24 gio sinh canh bao "mat tam nhin" va van giu ho so o trang thai stale, khong bi xoa.
- Truy van osquery that bai tren mot host khong lam that bai ca dot quet; loi duoc ghi vao Collection Run kem host cu the.

FR-01.2 Discovery Docker va Docker Compose

Voi host chay Docker, collector doc qua Docker API (read-only socket proxy hoac TLS) danh sach container, image, network, volume, port mapping, label va bien moi truong (chi ten bien, khong gia tri neu bien chua secret). Neu co file Compose trong nguon cau hinh da dang ky, he thong lien ket container ve service tuong ung. Container khong co label, khong co owner va khong khop service nao se bi gan co "shadow / chua dang ky".

FR-01.3 Discovery Kubernetes (2 cluster: dev va prod)

Moi cluster dang ky bang mot ServiceAccount chi doc (get/list/watch tren namespace duoc phep). Collector thu thap: namespace, workload (Deployment/StatefulSet/DaemonSet/Job), pod, container va image digest, Service, Ingress/Gateway, ConfigMap (chi ten khoa), NetworkPolicy, ServiceAccount, resource requests/limits va owner reference. Cluster dev va prod phai tach biet credential, tach nhan moi truong va khong dung chung token. Su kien thay doi tren prod (workload moi, image moi, Ingress moi) phai phat hien trong <= 15 phut.

Tieu chi nghiem thu (Acceptance Criteria):

- Tao mot Ingress moi tren prod chua dang ky se xuat hien trong danh sach exposure kem canh bao trong <= 15 phut.
- Xoa mot workload khong lam mat lich su: deployment chuyen trang thai retired kem thoi diem lan cuoi con thay.

FR-01.4 Discovery agentless bo sung

Voi server khong co osquery, Platform ho tro doc qua API ao hoa/cloud (neu co), qua danh sach host tu log tap trung, va qua doi chieu DNS. Cac tai san chi thay qua log/DNS ma khong co nguon xac nhan truc tiep phai gan confidence = inferred va dua vao hang doi "can xac minh" cho Infra xac nhan hoac loai bo.

FR-01.5 Loai trung va hop nhat tai san (Deduplication)

Cung mot may vat ly/ao co the xuat hien tu osquery, Docker va K8s (node). He thong phai hop nhat thanh mot Host duy nhat dua tren thu tu uu tien: host_uuid / instance ID, sau do MAC + hostname, sau do IP noi bo on dinh. Moi lan hop nhat phai ghi log quy tac da ap dung de truy vet khi hop nhat sai. Nguoi dung co quyen Infra tro len duoc tach/gop thu cong, va thao tac thu cong duoc ton trong o cac lan quet sau (khong tu dong gop lai).

FR-01.6 Phat hien tai san la va tai san ma (Shadow va Stale)

- **Shadow asset:** tai san thay tren he thong nhung khong co trong danh sach dang ky/owner - gan co, dua vao queue xac minh, canh bao Security neu lo ra ngoai.
- **Stale asset:** tai san da dang ky nhung khong con thay qua 2 chu ky quet - canh bao chu so huu xac nhan da ha (decommission) hay la mat tam nhin.
- **Orphan:** container/route/dns record tro toi dich khong con ton tai - liet ke rieng trong bao cao suc khoe inventory.

FR-01.7 Workstation: quan ly don gian theo site (uu tien thap)

Workstation khong chay discovery sau nhu server. Moi site co mot co che check-in nhe: agent nhe chi bao hostname, OS va phien ban chinh, nguoi dung dang dang nhap (ten tai khoan noi bo), thoi diem online gan nhat; hoac nhap dinh ky danh sach tu he thong quan ly hien co cua site (file/API) neu site da co. Giao dien workstation chi gom: danh sach theo site, tong so, ty le online trong 7 ngay, may lau chua check-in (>30 ngay), va tim kiem theo hostname/site. Khong thu thap process, cong nghe, package chi tiet, khong quet CVE tung workstation trong Phase 1/2.

Tieu chi nghiem thu (Acceptance Criteria):

- Trang Site hien dung tong workstation cua site va khop voi so check-in nhan duoc; lech so lieu phai co ly do (may moi, may da thu hoi) ghi trong ghi chu site.
- Workstation khong check-in 30 ngay tu dong chuyen trang thai inactive, khong sinh canh bao bao mat nghiem trong (chi la bao cao dinh ky).
- Khong co man hinh hay API nao yeu cau du lieu workstation sau hon muc neu tren trong Phase 1/2 - neu dev thay yeu cau nhu vay, phai xin phe duyet pham vi rieng.

FR-01.8 Dang ky thu cong va nhap khau

Cho phep dang ky thu cong tai san khong the tu dong phat hien (vi du thiet bi mang, dich vu SaaS dung cho noi bo) qua form va nhap CSV co mau chuan, co buoc xem truoc (preview) va bao loi tung dong. Du lieu nhap tay phai gan source = manual va nguoi nhap, de phan biet voi du lieu tu dong khi danh gia do tin cay.

10. FR-02 Tech Stack va Version Intelligence

Muc tieu: tra loi chinh xac "moi noi dang chay cai gi, phien ban nao, con duoc ho tro khong, lech nhau o dau" cho ca tang he dieu hanh, runtime, framework, web server, co so du lieu va thu vien.

FR-02.1 Nhan dien stack theo nhieu tang

Tang	Vi du phai nhan dien duoc	Nguon nhan dien uu tien
He dieu hanh	Ubuntu 22.04, Debian 12, Windows Server 2022	osquery os_version, /etc/os-release

Tang	Vi du phai nhan dien duoc	Nguon nhan dien uu tien
Runtime	OpenJDK 8/11/17/21, Node.js 18/20, Python 3.9/3.11, .NET 6/8, Go, PHP	Package, process command line, image layer
Web / App server	Nginx, Apache, Tomcat, Traefik version	Package, banner (chi la phu), process
Framework / Library	Spring, Django, Laravel, Log4j, OpenSSL...	SBOM cua image, package manager, manifest repo neu duoc lien ket
Database / Middleware	PostgreSQL, MySQL, Redis, Kafka, RabbitMQ + version	Process, port da xac nhan, package, K8s workload label
Container base	alpine, debian-slim, distroless, ubuntu + tag/digest	Image metadata va SBOM

Quy tac nhan dien: uu tien bang chung manh (package da cai, SBOM, image digest) hon bang chung yeu (banner, suy doan tu port). Moi ket luan stack phai kem bang chung va do tin cay. Neu hai nguon mau thuan ve version, he thong hien thi ca hai kem nguon, va tao Finding loai "du lieu mau thuan" thay vi tu chon mot cai va im lang.

FR-02.2 SBOM cho container image

Moi image duoc quet de sinh SBOM (dinh dang SPDX hoac CycloneDX) o lan dau thay va khi digest thay doi. SBOM la co so de doi chieu CVE cap thu vien ma quet package OS khong thay duoc. Luu tru SBOM theo digest, khong quet lai image khong doi. Thoi gian quet mot image thong thuong phai duoi 5 phut trong hang doi nen; image lon duoc xu ly bat dong bo va hien trang thai "dang quet".

FR-02.3 Vong doi ho tro va EOL

He thong duy tri bang vong doi (co the dong bo tu nguon du lieu EOL cong khai va bo sung thu cong co phe duyet) cho OS, runtime va database pho bien. Moi thanh phan da qua EOL, hoac con duoi 90 ngay toi EOL, phai bi gan co va tinh vao diem rui ro. Bao cao EOL liet ke kem ke hoach nang cap neu chu so huu da khai bao, hoac danh dau "chua co ke hoach".

FR-02.4 Lech version (Version Drift) trong noi bo

Voi cung mot stack, he thong gom nhom cac version dang chay va lam noi bat: version thieu so (chi 1-2 noi chay version rieng le), version cu hon version chuan da khai bao (golden version neu team dinh nghia), va lech giua dev va prod (dev moi hon prod qua 2 ban chinh, hoac prod chay version ma dev khong he thu). Day la bao cao suc khoe ky thuat, khong tu dong la Finding bao mat, tru khi version lech do co CVE.

Tieu chi nghiem thu (Acceptance Criteria):

- Tim kiem "Log4j" tra ve dung danh sach host/image dang chay tung version, kem bang chung nguon cho tung dong.
- Trang chi tiet mot stack hien: so noi dang chay, phan bo version, trang thai EOL va danh sach CVE dang mo lien quan.
- Sua version bang tay bi cam: version chi den tu collector/SBOM; nguoi dung chi duoc gan ghi chu giai thich, khong sua so lieu goc.

11. FR-03 Network, Firewall va Traffic Flow

FR-03.1 Ban do cong nghe va dich vu nghe (Listening Map)

Tu osquery (listening_ports, processes), Docker port mapping va K8s Service, he thong dung bang tong hop: host/container nao dang nghe cong nao, giao thuc gi, bind vao dia chi nao, tien trinh nao so huu, va cong do co duoc firewall cho phep tu dau. Cong nghe tren 0.0.0.0/:: duoc danh dau khac cong chi nghe 127.0.0.1. Cong nghe khong khop voi bat ky service da dang ky nao phai bi gan co "cong la".

FR-03.2 Firewall va quy tac loc

Thu thap quy tac firewall tu host (iptables/nftables/UFW/Windows Firewall qua osquery va lenh doc duoc duyet), tu cloud security group / network ACL (neu co API), va K8s NetworkPolicy. He thong chuan hoa ve cung mot mo hinh (nguon, dich, cong, giao thuc, cho phep/chan, thu tu uu tien) va canh bao cac mau nguy hiem: rule cho phep 0.0.0.0/0 vao cong quan tri (22, 3389) hoac cong du lieu (5432, 3306, 6379, 27017, 9200), rule qua rong khong con dung, va mau thuan giua cac lop (firewall host mo nhung security group dong va nguoc lai).

> **Canh bao:** Platform chi doc va phan tich firewall. Khong co chuc nang sua, them, xoa hay ap dung lai rule firewall trong Phase 1/2/3 cua tai lieu nay.

FR-03.3 Traffic Flow tu log

Tu log tap trung (log cua Traefik, Pomerium, firewall, flow log neu co), he thong suy ra luong traffic thuc te: nguon nao dang noi toi dich nao, qua cong nao, tan suat va lan cuoi thay. Luong suy ra tu log phai phan biet voi luong "duoc phep theo cau hinh": mot ket noi duoc phep nhung 90 ngay khong thay phat sinh la ung vien de siet lai; mot ket noi phat sinh nhung khong co rule tuong ung la canh bao nghiem trong can dieu tra. Giao dien luong traffic gom dang bang loc duoc va dang do thi quan he (chi ve toi da so nut cau hinh duoc de tranh roi, mac dinh gom nhom theo service).

FR-03.4 Phan doan mang va whitelist

He thong ghi nhan cac whitelist dang ap dung cho tung dich vu lo ra ngoai (theo IP nguon, theo mang, theo danh tinh IdP) va hien thi whitelist do ngay tren trang exposure cua dich vu. Whitelist rong nhung dich vu danh dau "noi bo" la mau thuan phai canh bao. Moi thay doi whitelist phat hien qua quet lai se tao su kien drift (FR-12) kem nguoi/nguon thay doi neu biet.

Tieu chi nghiem thu (Acceptance Criteria):

- Nhap mot cong (vi du 6379) tra ve toan bo noi dang nghe cong do, trang thai lo ra ngoai va whitelist tuong ung trong mot man hinh.
- Rule 0.0.0.0/0 vao cong 22 tren bat ky host nao deu tao Finding muc cao va canh bao trong vong mot chu ky quet.
- Do thi traffic cua mot service loc duoc theo khoang thoi gian va chi ro du lieu la "cau hinh" hay "quan sat tu log".

12. FR-04 Domain, DNS va Cloudflare Mapping

FR-04.1 Dong bo DNS tu Cloudflare - chi doc (READ-ONLY)

Platform ket noi Cloudflare bang API token chi co quyen doc (Zone Read, DNS Read) tren cac zone duoc chi dinh. Dinh ky (mac dinh 30 phut) va theo yeu cau thu cong, he thong keo toan bo DNS record cua tung zone: loai

record, gia tri, TTL, trang thai proxied (may chu Cloudflare dung truoc) va thoi diem quan sat. Token phai duoc luu trong kho bi mat (vault) cua Platform, khong ghi vao log, khong hien thi lai sau khi luu.

> **Canh bao:** Rang buoc cung C-01: Platform khong giu quyen ghi Cloudflare, khong co nut, API noi bo hay playbook nao sua, tao, xoa DNS record. Trong code, client Cloudflare chi duoc phep goi cac endpoint GET. QA phai co test chung minh yeu cau ghi bi chan o tang client va o tang phan quyen ung dung.

FR-04.2 Anh xa domain den dich vu (Domain-to-Service Resolution)

Voi moi domain/subdomain, he thong dung chuoi anh xa day du va hien thi trong mot man hinh: Domain -> DNS record -> (neu proxied) Cloudflare -> IP dich -> Host / Load Balancer -> Traefik route -> Pomerium policy -> Service -> Deployment/Container hien tai. Moi mat xich trong chuoi phai ghi nguon va thoi diem; mat xich nao khong xac dinh duoc phai hien thi ro "chua xac dinh" cung ly do (vi du: IP khong thuoc host nao trong inventory) chu khong duoc bo trong am tham.

FR-04.3 Phat hien bat thuong DNS

- **Subdomain treo (dangling):** CNAME tro toi dich vu ben ngoai da huy hoac host khong con ton tai - nguy co bi chiem subdomain. Tao Finding muc cao.
- **Record tro toi IP la:** IP khong thuoc bat ky host nao trong inventory va khong phai IP cua doi tac da dang ky.
- **Domain khong co dich vu:** co DNS record va co the co ca chung chi, nhung khong co route/service nao dap lai.
- **Thay doi DNS:** moi thay doi gia tri record, trang thai proxied hoac TTL vuot nguong deu tao su kien drift va canh bao neu domain thuoc nhom quan trong (critical).
- **Subdomain moi:** subdomain lan dau xuat hien phai vao hang doi xac minh ownership trong 7 ngay.

FR-04.4 Chung chi TLS gan voi domain

Voi moi domain public, he thong theo doi chung chi dang phuc vu (tu Traefik, tu quet TLS doc thu dong va tu log chung chi neu co): nha phat hanh, ngay het han, SAN bao phu nhung subdomain nao, va lech giua chung chi tren Cloudflare edge voi chung chi o origin. Canh bao het han o moc 30, 14 va 7 ngay; chung chi het han hoac khong khop hostname la Finding nghiem trong.

FR-04.5 Khuyen nghi DNS trong remediation - chi de xuat

Khi mot phat hien lien quan den DNS (vi du subdomain treo), Platform duoc phep sinh *khuyen nghi* dang van ban co cau truc: record can xem xet, hanh dong de xuat (xoa/sua/CNAME lai), ly do, rui ro neu khong lam, va cac buoc kiem tra sau khi con nguoi tu thuc hien tren Cloudflare. Khuyen nghi chi chuyen thanh ticket/nhiem vu cho nguoi co quyen; Platform theo doi trang thai ticket do va tu dong xac nhan ket qua o lan dong bo DNS tiep theo (record da bien mat/thay doi dung nhu de xuat hay chua). Platform khong tu thuc thi, khong tu dong dong ticket khi chua thay bang chung tren DNS thuc te.

Tieu chi nghiem thu (Acceptance Criteria):

- Trang chi tiet mot domain ve duoc chuoi anh xa den tan container/service hoac ghi ro mat xich nao chua xac dinh va vi sao.
- Bat ky co gang goi API ghi cua Cloudflare tu Platform deu bi chan va ghi audit log canh bao.
- Subdomain treo bi phat hien va co khuyen nghi kem ticket trong vong mot chu ky dong bo DNS.

13. FR-05 Edge, Route va Policy: Traefik, Pomerium, Keycloak

FR-05.1 Tong hop Traefik tu nhieu nguon phan tan

Traefik hien duoc cau hinh o nhieu noi (file, label Docker, K8s Ingress/IngressRoute, API). Collector phai doc tat ca cac nguon dang dung, chuan hoa thanh danh sach router thong nhat: host rule, path rule, entrypoint, TLS, middleware, service dich va nguon cau hinh cua tung router. He thong phai phat hien: router trung host+path nhung tro hai dich khac nhau (xung dot), router tro toi dich khong con ton tai, router khong co TLS tren domain public, va middleware bao mat bi tat hoac cau hinh khac chuan (vi du thieu rate limit, thieu security headers theo baseline da duyet).

FR-05.2 Tong hop Pomerium va chinh sach truy cap

Collector doc cau hinh Pomerium: route, policy (allowed_users, allowed_groups, allowed_domains), trang thai bat/tat xac thuc cho tung route, va cac route duoc danh dau public/ bypass. Moi route lo ra Internet phai tra loi duoc: co qua Pomerium khong, neu co thi ai duoc vao, neu khong thi vi sao (da dang ky ngoai le hay la lo hong chua biet).

FR-05.3 Keycloak lam nguon su that ve danh tinh

Collector doc (read-only) realm, client, group, role va cac thiet lap bao mat cua client tuong ung voi ung dung: bat buoc MFA chua, access token lifetime, redirect URI co qua rong khong (wildcard), client nao dung chung secret, client nao da lau khong dung. Platform khong luu mat khau hay secret cua Keycloak client - chi luu trang thai va dau hieu rui ro.

FR-05.4 Ma tran bao ve (Protection Matrix)

Dau ra quan trong nhat cua FR-05 la mot bang ma tran cho tat ca dich vu public: hang la dich vu/domain, cot la cac lop bao ve - co TLS hop le khong, co qua Traefik chuan khong, co Pomerium khong, co IdP (Keycloak) khong, co yeu cau MFA khong, co whitelist IP khong, nhom nao duoc phep. O nao thieu so voi baseline cua muc do quan trong tuong ung se to mau va tao Finding. Baseline theo muc do quan trong do Security Lead duyet va luu trong cau hinh, vi du: dich vu critical lo Internet bat buoc co IdP + MFA + whitelist hoac ly do ngoai le da phe duyet.

Tieu chi nghiem thu (Acceptance Criteria):

- Loc ma tran theo "public + khong IdP" tra ve dung danh sach dich vu dang lo khong bao ve danh tinh, khop voi cau hinh nguon khi kiem chung thu cong.
- Thay doi policy Pomerium (them nhom duoc phep) bi phat hien thanh su kien drift trong chu ky quet tiep theo.
- Route Traefik trung nhau bi liet ke kem ca hai nguon cau hinh gay xung dot, khong tu y chon mot cai lam dung.

14. FR-06 Exposure va Attack Surface

FR-06.1 Dinh nghia "lo ra ngoai" (Exposure)

Mot tai san/dich vu duoc coi la public khi ton tai duong di tu Internet toi no ma khong can VPN hay mang noi bo: co DNS public tro toi, hoac IP public nghe cong do, hoac route Traefik/Pomerium cong khai, hoac Ingress co dia chi ngoai. He thong phai tinh exposure bang hop cua nhieu bang chung, khong chi dua vao mot truong co/khong do con nguoi khai. Moi ket luan public deu phai chi ra duong di cu the (evidence path) - xem chuoi anh xa o FR-04.2.

FR-06.2 Phan loai muc lo va diem be mat tan cong

Muc	Dinh nghia	Vi du
Public - khong bao ve	Internet vao thang, khong IdP, khong whitelist	Trang quan tri, cong database mo thang
Public - co bao ve	Internet vao duoc nhung qua IdP/policy/whitelist	App qua Pomerium + Keycloak + MFA
Partner-only	Chi nguon cua doi tac da dang ky duoc vao	Webhook IP whitelist cua doi tac
Internal	Chi trong mang noi bo / VPN	Service noi bo giua cac host
Unknown	Chua du bang chung de phan loai	Tai san inferred tu log, chua xac minh

Dashboard be mat tan cong phai cho thay: tong so diem lo public theo muc, thay doi theo thoi gian (tuan nay tang bao nhieu diem lo moi), va danh sach diem lo moi xuat hien trong 7 ngay - day la con so lanh dao va Security xem dau tien moi tuan.

FR-06.3 Rule phat hien exposure nguy hiem (mac dinh, co the cau hinh)

- Cong quan tri (22, 3389, 2375 Docker API, 6443 K8s API) lo Internet.
- Cong du lieu (5432, 3306, 6379, 9200, 27017, 5672, 9092) lo Internet hoac lo sang mang khong tin cay.
- Trang/dich vu quan tri (admin panel, phpMyAdmin, K8s dashboard, Traefik dashboard) khong qua IdP.
- Container chay privileged, hoac mount docker.sock, lo kem dich vu public.
- Dich vu public dung HTTP thuan (khong TLS) hoac TLS het han.
- Bucket/dich vu luu tru cau hinh chia se cong khai (neu phat hien qua tich hop sau nay) - de trong giao dien rule de bo sung, khong cam ket o Phase 1.

Tieu chi nghiem thu (Acceptance Criteria):

- Tao thu mot container mo cong 6379 ra 0.0.0.0 tren host test thi Finding exposure xuat hien trong chu ky quet tiep theo kem duong di bang chung.
- Moi Finding exposure deu mo duoc ve trang chi tiet tai san va thay duong di public day du, khong chi la mot dong canh bao chung chung.

15. FR-07 CVE Impact Analysis va Remediation

Day la module trong tam vi muc tieu SEC cua khach hang: khi mot CVE duoc cong bo ve mot cong nghe nao do, Platform phai tra loi duoc ba cau hoi: chung ta co bi khong, bi o dau (host/service/version nao), va nen lam gi truoc. Trac nhiem cua module la tu dong hoa viec tra loi, khong de doi ngu ra soat bang tay.

FR-07.1 Dong bo du lieu lo hong

He thong dong bo dinh ky (mac dinh 4 gio) tu NVD, GHSA/OSV va danh sach CISA KEV; luu CVE, ban ghi diem CVSS, vector, mo ta, phien ban bi anh huong, phien ban da va, tai lieu tham chieu, co exploit cong khai hay khong (neu nguon co), chi so EPSS (neu co) va co nam trong KEV hay khong. Viec dong bo phai co co che cache va van hanh che do doc du lieu cu khi nguon ngoai loi, kem canh bao "du lieu CVE da cu X gio" tren giao dien.

FR-07.2 Doi chieu anh huong (Matching)

Risk Engine doi chieu ba lop: (1) package OS va thu vien trong SBOM khop CVE theo ecosystem va khoang version; (2) runtime/framework khop theo ten san pham va version; (3) cau hinh lien quan (vi du CVE chi khai thac duoc khi modun X bat) - neu khong xac dinh duoc dieu kien cau hinh, phai danh dau "co kha nang anh huong - can xac minh" chu khong duoc khang dinh chac chan. Moi ket qua khop tao/cap nhat mot Finding gan voi dung entity bi anh huong. False positive do nguoi dung xac nhan phai duoc ghi nho cho dung cap (san pham + version + nguon bang chung) de khong bao lai lap di lap lai.

FR-07.3 Vong doi cua Finding

Trang thai	Y nghia	Ai duoc chuyen
New	Vua phat hien, chua ai xem	He thong tao
Triaged	Da danh gia, da gan muc uu tien va owner	Security Analyst
In Progress	Dang xu ly theo khuyen nghi	Service Owner
Mitigated	Da giam rui ro tam thoi (vi du siet whitelist), chua va triet de	Owner + Security xac nhan
Resolved	Da va/nang version, da quet lai xac nhan het anh huong	He thong tu xac nhan + Owner dong
Accepted Risk	Chap nhan rui ro co thoi han, co phe duyet	Security Lead phe duyet, bat buoc co ngay het han
False Positive	Xac nhan khong bi anh huong, kem ly do va bang chung	Security Analyst

Finding qua han SLA (muc 15.5) ma chua xu ly phai tu dong leo thang thong bao. Finding o trang thai Accepted Risk het han se tu quay ve Triaged va canh bao lai.

FR-07.4 Bao cao anh huong theo CVE (CVE Impact Report)

Nhap mot ma CVE (hoac chon tu danh sach moi), he thong sinh bao cao mot trang in/xuat duoc: tom tat CVE va muc do, dang bi khai thac thuc te hay khong, tong so tai san bi anh huong phan theo moi truong (prod truoc dev), bang chi tiet tung host/service/container kem version hien tai, version can nang, trang thai lo ra ngoai, co IdP bao ve hay khong, whitelist hien tai, chu so huu va trang thai xu ly. Bao cao phai sinh xong trong duoi 60 giay voi quy mo hien tai va ghi ro thoi diem du lieu (data as-of).

FR-07.5 Khuyen nghi xu ly (Remediation Recommendation) va SLA

Muc do	Dieu kien dien hinh	SLA xu ly muc tieu	Hanh dong khuyen nghi mac dinh
Critical	KEV, hoac CVSS >=9, hoac co exploit va lo Internet	24 gio giam rui ro, 7 ngay va triet de	Nang len ban da va ngay; neu chua va duoc: siet whitelist / dua sau IdP / tam dung lo public
High	CVSS 7-8.9 hoac lo Internet khong KEV	14 ngay	Len ke hoach nang version trong sprint gan nhat, gan owner va ticket
Medium	CVSS 4-6.9, chi noi bo	30 ngay	Gom vao ke hoach nang cap dinh ky, theo doi EOL
Low	CVSS <4, khong lo, khong exploit	90 ngay / chap nhan rui ro	Ghi nhan, danh gia lai moi quy

Moi Finding phai kem khuyen nghi cu the theo dung ngu canh: nang len version nao (fixed version gan nhat phu hop), lam o dau (host/image nao), neu khong nang duoc ngay thi bien phap giam rui ro tam thoi nao kha thi (siet firewall/whitelist, bat IdP/MFA, tat tinh nang), va cach kiem chung sau khi lam (quet lai thay gi thi duoc dong). Khuyen nghi lien quan den Cloudflare DNS chi o dang de xuat cho con nguoi thuc hien (FR-04.5) - tuyet doi khong co buoc "Platform tu sua DNS". He thong duoc tao ticket tren cong cu quan ly cong viec hien co (neu tich hop) hoac xuat danh sach viec can lam; khong tu dong thay doi he thong dich.

FR-07.6 Diem rui ro (Risk Score)

Moi Finding va moi tai san co diem rui ro 0-100 tinh theo cong thuc o Phu luc C, ket hop: muc nghiem trong CVE, dang bi khai thac/exploit, muc lo ra ngoai, co bao ve IdP/MFA/whitelist hay khong, muc quan trong cua tai san va tuoi cua phat hien. Diem phai giai thich duoc: bam vao diem thay tung yeu to dong bao nhieu, khong phai hop den.

Tieu chi nghiem thu (Acceptance Criteria):

- Voi mot CVE mau thuoc KEV va mot image dang chay dung version bi anh huong tren prod lo Internet, Finding Critical duoc tao tu dong kem bao cao anh huong day du cac truong o 15.4.
- Sau khi owner nang image len fixed version va collector quet lai, Finding tu chuyen Resolved kem bang chung version moi.
- Khuyen nghi cho Finding lien quan DNS khong chua bat ky hanh dong tu dong nao voi Cloudflare; chi co de xuat va lien ket ticket.

16. FR-08 Search, Dashboard va Bao cao

FR-08.1 Tim kiem toan van va tim kiem co cau truc

O tim kiem trung tam tim duoc theo: hostname, IP, domain, ten service, ten image, ten package, ma CVE, cong, ten nguoi/team so huu va bat ky tag nao. Ho tro toan tu loc co cau truc, vi du: `stack:log4j version:<2.17 env:prod exposed:true`, `port:6379 exposed:true`, `cve:CVE-XXXX owner:team-a status:open`. Ket qua nhom theo loai tai san, hien thi do tin cay va thoi diem cap nhat, va cho luu truy van lam "goc nhin da luu" (saved view) chia se cho team. Thoi gian phan hoi tim kiem thong thuong duoi 2 giay o quy mo hien tai.

FR-08.2 Dashboard

- **Tong quan dieu hanh:** tong tai san theo loai va moi truong, ty le co owner, so tai san stale/shadow, suc khoe collector (nguon nao dang im lang).

- **An toan:** so Finding mo theo muc do va tuoi, top CVE nong (KEV), so diem lo public va bien dong 7/30 ngay, ty le dich vu public co IdP/MFA.
- **Ky thuat:** phan bo version cua cac stack chinh, danh sach EOL sap toi, drift moi trong 24 gio.
- Moi con so tren dashboard deu bam duoc xuong danh sach chi tiet tuong ung (drill-down) - khong co con so "chet" khong truy nguoc duoc.

FR-08.3 Bao cao va xuat du lieu

Bao cao chuan: (1) Inventory day du, (2) Exposure / Attack Surface, (3) CVE Impact theo ma CVE, (4) EOL va Version Drift, (5) Ownership - tai san chua co chu, (6) Workstation theo site, (7) Thay doi trong ky (drift report). Dinh dang xuat: PDF (de gui lanh dao/audit), CSV va XLSX (de xu ly tiep), JSON qua API. Moi bao cao ghi: nguoi xuat, thoi diem xuat, bo loc da dung va thoi diem du lieu (as-of) de tranh hieu nham bao cao cu la hien tai.

17. FR-09 den FR-12: Canh bao, Ownership, Audit, Lich su

FR-09 Canh bao (Alerting)

Ken h canh bao: email va kenh chat noi bo (Slack/Teams/Telegram tuy cau hinh - chi cam ket kenh cong ty dang dung khi xac nhan o Sprint 0). Su kien canh bao mac dinh: Finding Critical moi, diem lo public moi, collector mat tam nhin qua nguong, chung chi sap het han, drift tren prod thuoc nhom quan trong. Canh bao phai co co che gom nhom (tranh bao spam: cung mot nguyen nhan chi bao mot lan trong cua so cau hinh), lien ket thang toi Finding/tai san, va nut xac nhan da xem. Ngoai gio lam viec chi Finding Critical moi danh thuc kenh truc - cau hinh nay do Security Lead duyet.

FR-10 Ownership va quy trinh xac nhan

Moi service, host va domain phai co owner (team). He thong tu de xuat owner dua tren bang chung (label, repo, nguoi tao resource, lich su dang nhap quan tri) kem do tin cay, nhung owner chi chinh thuc khi con nguoi xac nhan. Quy trinh: tai san chua co chu vao queue, Infra gan de xuat, team duoc de xuat xac nhan hoac tu choi kem ly do, qua 14 ngay khong phan hoi thi leo thang len quan ly. Trang thai ownership la mot phan cua diem suc khoe inventory tren dashboard.

FR-11 Audit Log cua chinh Platform

Moi hanh dong ghi trong Platform (dang nhap, xem truong nhay cam, sua metadata, phe duyet ngoai le, xuat bao cao, thay doi cau hinh collector/nguong canh bao) deu ghi vao audit log chi them (append-only), khong sua/xoa duoc ke ca boi Admin ung dung. Audit log tra cuu duoc theo nguoi, hanh dong, doi tuong va thoi gian, va duoc luu toi thieu 12 thang.

FR-12 Lich su, Snapshot va Drift Detection

He thong giu snapshot theo tung dot thu thap va tinh chenh lech (diff) giua hai moc thoi gian bat ky cho mot tai san hoac toan he thong: them/bot host, container, cong nghe, route, policy, DNS record, version thay doi. Man hinh "Thay doi" la noi tra loi cau hoi "dem qua co gi khac?" va la nguon cua canh bao drift. Thoi gian luu lich su chi tiet: toi thieu 90 ngay o muc entity, 12 thang o muc tong hop/su kien quan trong. Viec don dep du lieu cu phai la tac vu nen co ghi log, khong lam mat Finding dang mo va lich su cua chung.

> **Tieu chi nghiem thu (Acceptance Criteria):**
>
> - Chon hai ngay bat ky, he thong liet ke dung cac thay doi ve route/policy/DNS/version trong khoang do.
> - Sua owner cua mot service thi audit log co ban ghi day du va snapshot khong bi viet lai lich su cu.

- Canh bao trung lap do cung mot Finding gay ra trong cua so gom nhom chi gui mot lan.

18. Luong nghiep vu chinh (Use Cases)

UC-01 - Ung pho mot CVE moi cong bo

Tac nhan chinh: Security Analyst

Luong chinh: 1. Nhan canh bao CVE thuoc KEV hoac tim ma CVE tren Platform. 2. Mo CVE Impact Report (FR-07.4). 3. Loc theo prod va exposure public. 4. Kiem tra khuyen nghi va fixed version. 5. Tao ticket cho tung owner, gan SLA. 6. Theo doi trang thai; he thong tu xac nhan khi quet lai thay version da va.

Ngoai le / luu y: Khong co tai san nao khop: bao cao ghi ro "0 anh huong" kem pham vi da doi chieu va thoi diem du lieu CVE. Version khong xac dinh duoc: liet ke vao muc "can xac minh thu cong", khong bo qua.

UC-02 - Kiem tra mot domain dang tro di dau

Tac nhan chinh: Infra / Security

Luong chinh: 1. Tim domain. 2. Xem chuoi anh xa FR-04.2 den tan service/container. 3. Xem policy, IdP, whitelist va chung chi. 4. Neu co mat xich chua xac dinh, tao viec xac minh cho owner duoc de xuat.

Ngoai le / luu y: IP dich khong thuoc inventory: gan co "IP la", tao Finding va de xuat kiem tra nguon goc DNS record (chi khuyen nghi, khong sua DNS).

UC-03 - Ra soat be mat tan cong hang tuan

Tac nhan chinh: Security Lead

Luong chinh: 1. Mo dashboard exposure. 2. Xem diem lo moi trong 7 ngay va ma tran bao ve FR-05.4. 3. Loc "public + khong IdP". 4. Gan owner va han xu ly cho tung muc. 5. Xuat bao cao tuan.

Ngoai le / luu y: Dich vu public la chu dich (vi du trang cong khai): phai co ghi nhan ngoai le da duyet thi moi khong bi tinh la Finding.

UC-04 - Tiep nhan mot server moi

Tac nhan chinh: Infra Engineer

Luong chinh: 1. Cai osquery / cap quyen collector. 2. Cho discovery tu dong (UC ngam). 3. Xac nhan hop nhat tai san, gan owner, moi truong va muc quan trong. 4. Kiem tra Finding ban dau (cong lo, EOL, CVE).

Ngoai le / luu y: Host trung voi tai san cu da retired: he thong de xuat "hoi sinh" ban ghi cu de giu lich su, nguoi dung quyet dinh.

UC-05 - Xac nhan ownership hang loat

Tac nhan chinh: Team Lead cac team

Luong chinh: 1. Mo queue ownership cua team minh. 2. Xem de xuat kem bang chung. 3. Xac nhan / tu choi kem ly do tung muc hoac hang loat cho cac muc cung bang chung.

Ngoai le / luu y: Tu choi phai co ly do; muc bi tu choi quay lai queue cua Infra kem lich su de xuat.

UC-06 - Chuan bi bao cao audit

Tac nhan chinh: Auditor / Security

Luong chinh: 1. Chon mau bao cao audit. 2. Chon ky bao cao va pham vi. 3. Xuat PDF kem trang thong tin nguoi xuat, bo loc, as-of. 4. Gui kem danh sach ngoai le rui ro dang con hieu luc.

Ngoai le / luu y: Du lieu thieu (collector im lang trong ky): bao cao phai ghi ro pham vi du lieu chua day du, khong duoc im lang bo qua.

UC-07 - Dieu tra cong la tren mot host

Tac nhan chinh: Security Analyst

Luong chinh: 1. Tu canh bao cong la, mo chi tiet host. 2. Xem tien trinh so huu cong, service lien quan, firewall va traffic log. 3. Ket luan: dich vu hop le chua dang ky (thi dang ky va gan owner) hoac bat thuong (thi tao su co bao mat theo quy trinh rieng ngoai Platform).

Ngoai le / luu y: Platform khong tu dong dong cong hay giet tien trinh - dieu tra va xu ly nam ngoai Platform.

UC-08 - Quan ly workstation theo site

Tac nhan chinh: IT theo site

Luong chinh: 1. Mo trang Site. 2. Xem tong may, ty le online, may lau chua check-in. 3. Cap nhat ghi chu (may moi, may thu hoi, may hong). 4. Xuat danh sach cua site khi can doi soat.

Ngoai le / luu y: May check-in bang hostname trung voi may khac o site khac: phan biet bang site_id + dinh danh may, dua vao danh sach can doi soat thu cong.

19. User Stories va tieu chi nghiem thu tong hop

Uu tien: P0 = bat buoc cho Phase 1, P1 = Phase 2, P2 = Phase 3 / nice-to-have. Moi story deu nghiem thu bang tieu chi trong FR tuong ung cong voi tieu chi rieng ghi o day.

Ma	Uu tien	Vai tro	Nhu cau (Nhu mot..., toi muon...)	Tieu chi nghiem thu chinh
US-01	P0	Security Analyst	Xem danh sach toan bo server kem OS, version, owner va lan thay cuoi	Loc duoc theo moi truong/site/owner; server stale duoc danh dau ro
US-02	P0	Infra Engineer	Biet server moi tu dong xuat hien sau khi cai osquery ma khong can nhap tay	Xuat hien trong 30 phut, kem nguon phat hien
US-03	P0	Security Analyst	Tim theo ten package/thu vien va thay moi noi dang chay version nao	Ket qua gom host va image, kem bang chung nguon
US-04	P0	Security Analyst	Nhap ma CVE va nhan bao cao anh huong day du	Bao cao dung mau FR-07.4, sinh duoi 60 giay
US-05	P0	Security Lead	Thay danh sach dich vu public khong qua IdP	Danh sach khop ma tran bao ve FR-05.4 khi kiem chung
US-06	P0	Infra Engineer	Tim mot domain va thay no tro toi host/service nao	Chuoi anh xa day du hoac ghi ro mat xich thieu
US-07	P0	Security Analyst	Duoc canh bao khi co diem lo public moi	Canh bao trong mot chu ky quet, kem duong di bang chung
US-08	P0	Service Owner	Nhan danh sach Finding cua service minh kem viec can lam cu the	Moi Finding co fixed version hoac giam rui ro tam thoi va cach kiem chung
US-09	P0	Auditor	Xuat bao cao inventory va exposure co as-of va nguoi xuat	File PDF/CSV mo duoc, so lieu khop drill-down tai thoi diem xuat
US-10	P0	Admin	Biet collector/nguon nao dang im lang	Dashboard suc khoe collector va canh bao mat tam nhin hoat dong
US-11	P1	Security Analyst	Thay traffic flow thuc te giua cac service tu log	Phan biet duoc luong cau hinh va luong quan sat
US-12	P1	Infra Engineer	Nhan canh bao drift khi route/policy/DNS thay doi	Su kien drift kem diff cu/moi va nguon thay doi
US-13	P1	Team Lead	Xac nhan ownership hang loat cho service cua team	Queue, bang chung de xuat va lich su xac nhan day du
US-14	P1	IT theo site	Xem tong workstation va may lau chua check-in theo site	Chi o muc tong hop/check-in, khong yeu cau du lieu sau
US-15	P1	Security Analyst	Danh dau chap nhan rui ro co thoi han cho mot Finding	Bat buoc co ly do, nguoi duyet va ngay het han; het han tu mo lai
US-16	P1	DevOps	So sanh version cua cung mot stack giua dev va prod	Bao cao drift version loc duoc theo stack
US-17	P2	Security Lead	Tao remediation recommendation thanh ticket tren cong cu quan ly viec	Ticket chua dung noi dung khuyen nghi va lien ket nguoc ve Finding; khong tu dong thay doi he thong dich, khong sua DNS Cloudflare

Ma	Uu tien	Vai tro	Nhu cau (Nhu mot..., toi muon...)	Tieu chi nghiem thu chinh
US-18	P2	Service Owner	Xem diem rui ro cua service minh va hieu vi sao co diem do	Bam vao diem thay phan ra tung yeu to (Phu luc C)

20. API Specification

API noi bo dung REST/JSON qua HTTPS, xac thuc bang phien dang nhap SSO cho nguoi dung va bang token co scope cho service account/collector. Moi phan hoi danh sach deu phan trang (mac dinh 50, toi da 200), sap xep on dinh, va tra kem `as_of`. Loi tra theo dinh dang thong nhat: ma loi, thong diep cho nguoi doc, va request_id de truy vet log. Version API qua duong dan `/api/v1/`; thay doi pha vo tuong thich phai len version moi.

Method	Duong dan	Mo ta	Quyen toi thieu
GET	/api/v1/assets	Liet ke tai san (loc: type, env, site, owner, tag, q)	Viewer+
GET	/api/v1/assets/{id}	Chi tiet tai san kem quan he va bang chung nguon	Viewer+
GET	/api/v1/hosts/{id}/ports	Cong nghe va tien trinh cua mot host	Viewer+
GET	/api/v1/search?q=	Tim kiem toan van + cu phap loc cau truc (FR-08.1)	Viewer+
GET	/api/v1/domains/{fqdn}/resolution	Chuoi anh xa domain den service (FR-04.2)	Viewer+
GET	/api/v1/dns/records	DNS records da dong bo tu Cloudflare (chi doc du lieu da keo ve)	Viewer+
GET	/api/v1/protection-matrix	Ma tran bao ve dich vu public (FR-05.4)	Viewer+
GET	/api/v1/findings	Danh sach Finding (loc: severity, status, owner, cve, overdue)	Viewer+
PATCH	/api/v1/findings/{id}	Doi trang thai Finding, gan owner, ghi chu (ghi audit)	Security/Owner
POST	/api/v1/findings/{id}/accept-risk	Chap nhan rui ro co thoi han (can ly do + han)	Security Lead
GET	/api/v1/cves/{cve_id}/impact	Bao cao anh huong theo CVE (FR-07.4)	Viewer+
GET	/api/v1/stacks	Phan bo stack/version va EOL (FR-02)	Viewer+
GET	/api/v1/exposure	Danh sach diem lo va muc lo (FR-06)	Viewer+
GET	/api/v1/drift	Su kien thay doi theo khoang thoi gian	Viewer+
GET	/api/v1/sites	Danh sach site va tong hop workstation	Viewer+
GET	/api/v1/sites/{id}/workstations	Workstation cua mot site (muc thong tin don gian)	Viewer+
POST	/api/v1/ingest/osquery	Nhan ket qua osquery (collector)	Service: ingest-osquery
POST	/api/v1/ingest/events	Nhan su kien collector (Docker/K8s/Traefik...)	Service: ingest-events
POST	/api/v1/workstations/check-in	Check-in nhe cua workstation theo site	Service: workstation-checkin
GET	/api/v1/collectors/health	Suc khoe va lan chay cua cac collector	Viewer+
POST	/api/v1/reports	Tao bao cao bat dong bo (PDF/CSV/XLSX/JSON)	Viewer+

Method	Duong dan	Mo ta	Quyen toi thieu
GET	/api/v1/reports/{id}	Trang thai va tai bao cao	Viewer+ (chi nguoi tao hoac Admin/Auditor)
GET	/api/v1/audit-log	Tra cuu audit log	Admin / Auditor

> **Luu y:** Khong ton tai bat ky endpoint nao ghi xuong he thong dich (khong endpoint sua firewall, sua DNS, restart service). Neu mot yeu cau tuong lai can cac endpoint do, phai co dac ta bo sung va phe duyet rieng cua Sponsor va Security Lead.

Vi du: phan hoi rut gon cua GET /api/v1/cves/{cve_id}/impact

```
{ "cve_id": "CVE-YYYY-NNNNN", "as_of": "2026-10-23T09:00:00+07:00",
  "summary": {"affected_total": 7, "affected_prod": 5, "exposed_public": 2, "kev_listed": true},
  "affected": [{"asset_type": "image", "service": "vi-du-service", "environment": "prod",
    "current_version": "x.y.z", "fixed_version": "x.y.z+fix", "exposure": "public-protected",
    "owner": "team-vi-du", "finding_id": "...", "finding_status": "new"}] }
```

Vi du tren dung gia tri gia dinh. Cau truc truong la chuan bat buoc; gia tri phai den tu du lieu that khi van hanh.

21. Bao mat cho chinh Platform

Platform tap trung ban do tan cong cua toan bo cong ty vao mot noi - neu bi xam nhap, ke tan cong co san ban do de di tiep. Vi vay Platform phai duoc bao ve nhu he thong nhay cam bac cao nhat, va cac yeu cau sau la bat buoc, khong phai tuy chon.

- **Truy cap:** chi qua mang noi bo/VPN hoac IdP co MFA; khong lo Platform ra Internet cong khai. Dang nhap qua Keycloak SSO, phien lam viec co thoi han, khoa tai khoan khi co dau hieu bat thuong theo chinh sach chung cua cong ty.
- **Phan quyen va tach quyen:** RBAC o muc 5.2 ap dung ca UI lan API; service account cua tung collector tach rieng, chi ghi duoc loai du lieu cua no, mat mot token khong mo duong sang cac nguon khac.
- **Bi mat:** moi token/API key (Cloudflare read-only, K8s, Keycloak...) luu trong vault, ma hoa khi luu tru, xoay vong (rotate) dinh ky va khi co nhan su thay doi; khong ghi bi mat vao log, bao cao hay ma nguon.
- **Du lieu nhay cam:** khong thu thap gia tri bien moi truong nghi la secret, khong luu noi dung file cau hinh chua khoa; chi luu ten khoa va dau vet (hash) neu can doi chieu thay doi. Du lieu workstation chi o muc da neu o FR-01.7, khong mo rong thu thap du lieu ca nhan.
- **Ma hoa va sao luu:** TLS cho moi ket noi vao Platform; ma hoa o tang luu tru; sao luu co kiem tra khoi phuc dinh ky (restore test), vi mat Platform giua mot dot ung pho CVE la kich ban phai chuan bi.
- **Giam sat chinh Platform:** log truy cap va audit log gui ve he thong log tap trung; canh bao khi co truy van hang loat, xuat bao cao bat thuong, hoac dang nhap ngoai khung gio/thiet bi la.
- **Phat trien an toan:** code review bat buoc, quet phu thuoc (dependency scanning) cho chinh Platform, va kiem thu xam nhap (pentest noi bo hoac ben ngoai) truoc khi dua du lieu prod that vao Phase 1 chinh thuc.

Tieu chi nghiem thu (Acceptance Criteria):

- Pentest/kien tra bao mat truoc go-live khong con phat hien Critical/High chua xu ly.
- Thu thu hoi token cua mot collector thi chi nguon do ngung cap nhat va sinh canh bao; cac nguon khac khong bi anh huong.
- Xuat bao cao hang loat bat thuong bi ghi audit va canh bao cho Admin.

22. Yeu cau phi chuc nang (NFR)

Ma	Hang muc	Yeu cau do duoc
NFR-01	Hieu nang tim kiem	Tim kiem thong thuong phan hoi < 2 giay (p95) voi 150 server, 500 workstation, ~2 cluster va du lieu 90 ngay
NFR-02	Hieu nang bao cao	CVE Impact Report sinh < 60 giay; bao cao lon chay bat dong bo va thong bao khi xong
NFR-03	Do tuoi du lieu	Server/K8s prod: du lieu khong cu qua 30 phut trong dieu kien binh thuong; DNS: khong qua 60 phut; workstation check-in: danh gia theo ngay, khong theo phut
NFR-04	Do kha dung	Platform dat >= 99,5% trong gio lam viec; collector chet khong lam sup giao dien doc du lieu cu
NFR-05	Kha nang mo rong	Kien truc chiu duoc gap 3 quy mo hien tai (450 server) ma khong phai thiet ke lai; vuot nguong nay phai danh gia lai
NFR-06	Do tin cay ingest	Gui trung du lieu khong tao trung tai san (idempotent); mat du lieu mot chu ky quet phai phat hien duoc
NFR-07	Sao luu / khoi phuc	RPO <= 24 gio, RTO <= 8 gio lam viec; kiem tra khoi phuc it nhat moi quy
NFR-08	Tinh de dung	Nguoi dung moi (Viewer) tim duoc cau tra loi cho UC-02 trong < 3 phut ma khong can dao tao; giao dien tieng Viet la chinh, thuat ngu ky thuat giu tieng Anh khi la chuan nganh
NFR-09	Truy cap	Giao dien web hoat dong tren trinh duyet hien dai pho bien cua cong ty; tuong phan mau dat muc de doc voi bao cao in
NFR-10	Ghi log va quan sat	Moi loi collector/API co request_id truy vet duoc; co trang thai he thong noi bo cho Admin
NFR-11	Bao tri	Cap nhat bang CVE/EOL/rule khong can deploy lai; thay doi nguong canh bao qua cau hinh co ghi audit
NFR-12	Tuong thich du lieu	Xuat CSV/XLSX/JSON dung cau truc on dinh; doi cau truc phai co ghi chu phien ban

23. Tich hop ben ngoai va Collector Specification

Nguon	Cach doc	Tan suat mac dinh	Quyen toi thieu	Loi thi sao
osquery tren server	Truy van theo lich qua he thong quan ly osquery hien co (hoac FleetDM neu dung)	15 phut co ban / 6 gio sau	Chi chay truy van da duyet	Danh dau host stale sau 24 gio, canh bao mat tam nhin
Docker Engine	API read-only qua socket proxy/TLS	15 phut + theo su kien neu co	Doc container/image/network	Ghi loi vao Collection Run, thu lai chu ky sau
Kubernetes dev	API server, ServiceAccount chi doc	Watch + liet ke lai 30 phut	get/list/watch pham vi namespace duoc phep	Canh bao neu mat ket noi > 30 phut
Kubernetes prod	API server, ServiceAccount chi doc rieng cho prod	Watch + liet ke lai 15 phut	get/list/watch pham vi duoc phep	Canh bao uu tien cao neu mat ket noi > 15 phut

Nguon	Cach doc	Tan suat mac dinh	Quyen toi thieu	Loi thi sao
Traefik	API / file cau hinh / label da thu thap	15 phut	Doc cau hinh	Danh dau du lieu route la stale, khong tu suy doan bo sung
Pomerium	API / file cau hinh	15 phut	Doc route va policy	Tuong tu Traefik
Keycloak	Admin API read-only (tai khoan dich vu rieng)	6 gio	Doc realm/client/group/role	Canh bao neu dong bo loi 2 chu ky lien tiep
Cloudflare	API v4 - chi GET	30 phut	Zone Read + DNS Read tren zone chi dinh	Canh bao du lieu DNS cu; khong bao gio thu goi ghi de "sua tam"
Log tap trung	Doc/query theo API hoac file da tap hop	Lien tuc / 5 phut	Doc log trong pham vi duoc phep	Thieu log thi ha confidence cua traffic flow xuong inferred/thap
NVD / GHSA / OSV / KEV	Dong bo feed/API	4 gio	Cong khai / key neu can	Dung du lieu cu kem canh bao do tuoi du lieu
Workstation theo site	Agent nhe check-in hoac nhap danh sach cua site	Hang ngay	Chi gui thong tin check-in toi thieu	May khong check-in 30 ngay -> inactive

Moi collector phai co: trang cau hinh rieng (nguon, tan suat, trang thai lan chay cuoi, so ban ghi, loi gan nhat), nut "chay ngay" cho Admin, va co che tam dung rieng le. Truoc Sprint 1, Infra phai cap du quyen doc cho tung nguon trong bang tren va xac nhan bang checklist - thieu quyen cua nguon nao thi FR phu thuoc nguon do phai duoc danh dau rui ro trong ke hoach sprint, khong duoc gia dinh la se co sau.

24. Van hanh, giam sat va SLO

- **SLO du lieu:** 95% server bao du lieu dung han trong thang; vi pham SLO hai tuan lien tiep phai co bao cao nguyen nhan cho Infra Lead.
- **On-call:** Platform co nguoi truc theo mo hinh truc chung cua Infra; su co Platform khong duoc uu tien hon su co san xuat, nhung mat Platform qua 1 ngay lam viec phai leo thang.
- **Thay doi cau hinh quet:** tang tan suat quet tren prod phai duoc Infra phe duyet vi co the tang tai; moi thay doi ghi audit va co thoi gian thu (canary tren mot nhom host) truoc khi ap dung toan bo.
- **Moi truong:** Platform co moi truong thu nghiem rieng voi du lieu gia lap gan quy mo that (150 host ao) de kiem thu truoc khi doi collector hoac rule rui ro.
- **Ket thuc vong doi du lieu:** workstation inactive qua 180 ngay va host retired qua 12 thang duoc dua vao luu tru lanh theo chinh sach luu tru chung, Finding va audit log khong bi xoa theo.

25. Ke hoach trien khai, Migration va Roadmap

Thoi gian duoi day la khung tham chieu cho doi dev uoc luong lai bang story point sau Sprint 0 - BA khong cam ket ngay thang tuyet doi thay cho ke hoach cua Tech Lead. Thu tu uu tien la bat buoc: dung lam tinh nang Phase 2 trong khi discovery Phase 1 chua dang tin cay.

Sprint / moc	Noi dung	Dau ra kiem chung duoc
Sprint 0 - Chuan bi	Chot quyen doc cac nguon (muc 23), chot baseline bao ve, dung moi truong, xac nhan ty le host co osquery	Checklist quyen ky xac nhan; danh sach host muc tieu 150 server
Sprint 1-2	Khung Platform, SSO Keycloak, RBAC, ingest osquery + mo hinh Host, trang inventory server	150 server (hoac so thuc te da cap quyen) xuat hien dung tren UI
Sprint 3-4	Docker + K8s (dev truoc, prod sau), stack/version, SBOM image	Truy van stack/version dung tren mau kiem chung thu cong 20 service
Sprint 5	Cloudflare read-only, domain resolution chain, chung chi TLS	Chuoi anh xa dung cho 100% domain critical trong mau kiem chung
Sprint 6	Traefik + Pomerium + Keycloak policy, ma tran bao ve, exposure rules	Loc "public + khong IdP" dung khi doi chieu thu cong
Sprint 7	CVE feed, matching, Finding workflow, CVE Impact Report, SLA va canh bao	Chay thu ung pho mot CVE that trong qua khu va so sanh ket qua voi ra soat thu cong truoc day
Sprint 8	Workstation theo site, bao cao, audit log day du, cung bao mat va pentest	Bao cao audit xuat duoc; pentest khong con Critical/High
Go-live Phase 1	Dao tao nguoi dung, truc van hanh, theo doi KPI GO-01..GO-06 trong 30 ngay dau	Bao cao 30 ngay sau go-live cho Sponsor
Phase 2	Traffic flow sau, drift nang cao, ownership workflow day du, tich hop ticket	Theo exit criteria muc 4.3
Phase 3	Remediation workflow co phe duyet (tru Cloudflare DNS), bao cao tuan thu, API cho ben thu ba	Dac ta bo sung rieng duoc phe duyet truoc khi lam

25.1 Migration va du lieu ban dau

Khong co he thong inventory cu dang tin cay de migrate - du lieu ban dau duoc dung bang discovery tu dong. Cac danh sach roi rac hien co (file tinh, wiki, danh sach domain) chi duoc nhap lam nguon doi chieu (source = legacy-import, confidence = inferred) de phat hien lech, khong duoc coi la su that. Sau 30 ngay chay song song va doi chieu, cac nguon doi chieu nay duoc luu tru va ngung dung lam co so van hanh.

25.2 Dao tao va tiep nhan

- Tai lieu huong dan ngan (toi da 10 trang) cho tung vai tro kem 3 use case chinh cua vai tro do.
- Buoi dao tao 60 phut cho Security/Infra va 30 phut cho Service Owner, ghi hinh lai.
- Kenh ho tro noi bo trong 30 ngay dau sau go-live, cau hoi lap lai duoc dua vao FAQ va la dau vao cai tien tim kiem (FR-08).

26. Rui ro, van de mo va quyet dinh can chot

Ma	Rui ro / van de	Muc	Huong xu ly / nguoi quyet dinh
R-01	Ty le server thuc te co osquery thap hon gia dinh	Cao	Sprint 0 do lai chinh xac; neu <80%, bo sung ke hoach agentless va dieu chinh tien do - Sponsor quyet dinh
R-02	Quyen doc API cua mot so nguon (dac biet prod K8s) cham duoc cap vi lo anh huong san xuat	Cao	Dung ServiceAccount chi doc, thu tren dev truoc, co van ban cam ket read-only - Infra Lead
R-03	Du lieu policy Traefik/Pomerium phan tan va khong nhat quan giua cac nguon	Trung binh	Chap nhan hien thi mau thuan nhu mot loai Finding thay vi ep hop nhat - Security Lead

Ma	Rui ro / van de	Muc	Huong xu ly / nguoi quyet dinh
R-04	Bao dong gia (false positive) ve CVE/exposure lam team mat niem tin va bo qua canh bao that	Cao	Co co che xac nhan false positive co nho, do ty le bao dong gia hang tuan lam KPI chat luong - Security Lead
R-05	Platform tro thanh muc tieu tan cong gia tri cao	Cao	Ap dung muc 21 day du, pentest truoc go-live - Security Lead + Sponsor
R-06	Pham vi phong to: doi hoi remediation tu dong va quan ly workstation chi tiet som	Trung binh	Giu pham vi muc 4; moi mo rong phai qua Change Log va danh gia lai tien do - Sponsor
Q-01	CAN CHOT: Kenh chat canh bao chinh thuc la gi (Slack/Teams/khac)?	-	Sponsor/Security chot truoc Sprint 7
Q-02	CAN CHOT: Cong cu quan ly ticket hien tai la gi va co API khong?	-	Infra Lead chot truoc Sprint 7
Q-03	CAN CHOT: Baseline bao ve cho tung muc do quan trong (FR-05.4) - ai ky duyet ban dau tien?	-	Security Lead ky truoc Sprint 6
Q-04	CAN CHOT: Danh sach domain/service critical ban dau (lam mau kiem chung) gom nhung gi?	-	Sponsor + Infra cung cap truoc Sprint 5
Q-05	CAN CHOT: Site workstation gom nhung dia diem nao va dau moi tung site la ai?	-	Sponsor chot truoc Sprint 8

Change Log: Ban 1.0 (23/10/2026) - ban dau tien giao dev, da tich hop quy mo thuc te 150 server, 500 workstation theo site, 2 cluster Kubernetes (dev/prod) va rang buoc Cloudflare read-only do khach hang bo sung cung ngay. Moi thay doi sau ban nay phai ghi vao Change Log kem nguoi yeu cau, nguoi duyet va anh huong toi FR/NFR lien quan.

Phu luc A. Bang thuat ngu

Thuat ngu	Giai thich
Asset (tai san)	Bat ky doi tuong nao duoc quan ly: host, workstation, service, container, domain...
SBOM	Danh sach thanh phan phan mem trong mot image/ung dung (Software Bill of Materials)
CVE / KEV	Ma lo hong cong khai / danh sach CISA cac lo hong dang bi khai thac thuc te
EOL	End of Life - het ho tro, khong con ban va bao mat
Exposure	Muc do mot tai san co the bi cham toi tu ben ngoai / Internet
Finding	Mot phat hien can xu ly (CVE, exposure, drift, EOL, cau hinh sai) co vong doi rieng
Drift	Lech giua trang thai hien tai voi trang thai truoc do hoac voi chuan da duyet
IdP	Identity Provider - he thong xac thuc, o day la Keycloak, truy cap qua Pomerium
Collector	Thanh phan chi doc du lieu tu mot nguon va gui ve Platform
Site	Dia diem van phong/chi nhanh - don vi quan ly workstation

Phu luc B. Vi du truy van osquery (tham chieu cho dev)

Cac truy van duoi day la vi du khoi diem, dev phai kiem thu tren tung ho OS thuc te va chuan hoa cot tra ve truoc khi dua vao collector. Ten bang/cot theo schema osquery pho bien; neu phien ban osquery cua cong ty khac, phai doi chieu tai lieu schema tuong ung.

```
-- Host va he dieu hanh
SELECT hostname, cpu_brand, physical_memory FROM system_info;
SELECT name, version, build, platform FROM os_version;

-- Cong dang nghe va tien trinh so huu
SELECT p.port, p.protocol, p.address, pr.name AS process_name, pr.path
FROM listening_ports p JOIN processes pr ON p.pid = pr.pid;

-- Package da cai (Debian/Ubuntu)
SELECT name, version, source FROM deb_packages;

-- Container Docker (neu bang kha dung)
SELECT id, image, name, status FROM docker_containers;
SELECT image, tag, id FROM docker_images;
```

Nguyen tac an toan: chi chay truy van SELECT da duyet, khong chay truy van ghi/sua, gioi han thoi gian chay cho moi truy van va huy bo neu vuot nguong de tranh anh huong hieu nang host san xuat.

Phu luc C. Cong thuc tinh Risk Score

Risk Score cua mot Finding nam trong khoang 0-100, tinh tu cac yeu to sau (trong so mac dinh, Security Lead duoc sua qua cau hinh kem ghi audit):

Yeu to	Diem toi da	Cach tinh rut gon
Muc nghiem trong CVE / Finding	35	CVSS/10 x 35; Finding khong phai CVE dung bang anh xa severity cua rule

Yeu to	Diem toi da	Cach tinh rut gon
Dang bi khai thac	20	KEV = 20; co exploit cong khai = 14; co EPSS cao = toi da 10
Muc lo ra ngoai	20	Public khong bao ve = 20; public co bao ve = 10; partner = 6; internal = 2
Thieu bao ve bo sung	10	Khong IdP = 5; khong MFA (khi bat buoc) = 3; khong whitelist (khi bat buoc) = 2
Muc quan trong tai san	10	Critical = 10; High = 7; Medium = 4; Low = 2
Tuoi phat hien / qua SLA	5	Qua SLA = 5; sap qua SLA = 2
Tong	100	Cong lai, lam tron; >=75 Critical, 50-74 High, 25-49 Medium, <25 Low (hien thi)

Diem cua tai san la diem cao nhat cua cac Finding dang mo cua no, cong them 5 diem cho moi Finding nghiem trong thu hai tro di (toi da cong 15) de phan anh tich luy rui ro, va phai hien thi duoc phan ra tung yeu to khi nguoi dung bam vao diem.

> **Luu y:** Tai lieu ket thuc tai day. Cac cau hoi mo Q-01 den Q-05 o muc 26 can duoc chot truoc cac sprint tuong ung; dev khong tu gia dinh dap an cho cac cau hoi do. Khi co xung dot hieu biet, hoi lai BA/PO va ghi quyet dinh vao Change Log.